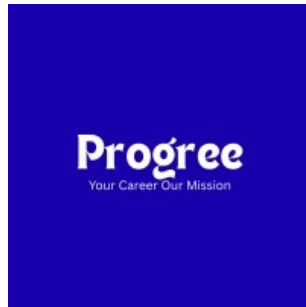




Enterprise Threat Modeling & Incident Response Blueprint

Task 4: Enterprise Cloud Platform Security Architecture

Prepared By:
Daaniya Absar

Date: September 1, 2026

Platform: Enterprise Cloud Platform

Framework: STRIDE, Zero-Trust, NIST IR

ProGree Internship Program

Confidential – For Internal Review Only

Contents

1	Executive Summary	3
1.1	Overview	3
1.2	Key Deliverables	3
1.3	Threat Landscape Summary	3
1.4	Recommendations	3
2	Enterprise System Architecture	4
2.1	Architecture Overview	4
2.2	Architecture Diagram	4
2.3	Component Descriptions	5
3	STRIDE Threat Modeling Framework	6
3.1	What is STRIDE?	6
3.2	STRIDE Threat Matrix	6
3.3	STRIDE Threat Summary	8
4	Zero-Trust Network Access Policy	9
4.1	Core Zero-Trust Principles	9
4.2	The Five Pillars of Zero-Trust	9
4.3	MFA Implementation Roadmap	10
4.4	Least Privilege Access Control	10
5	4-Stage Incident Response Lifecycle Plan	11
5.1	Overview	11
5.2	Incident Response Lifecycle Diagram	11
5.3	Stage 1: Preparation	12
5.3.1	1.1 Pre-Incident Preparation Checklist	12
5.3.2	1.2 Incident Response Team Structure	12
5.3.3	1.3 Incident Classification	12
5.4	Stage 2: Detection & Analysis	13
5.4.1	2.1 Detection Methods	13
5.4.2	2.2 Indicators of Compromise (IOCs)	13
5.4.3	2.3 Analysis Workflow	13
5.5	Stage 3: Containment, Eradication & Recovery	14
5.5.1	3.1 Ransomware Response Playbook	14
5.5.2	3.2 Database Breach Response Playbook	14
5.5.3	3.3 Containment Strategies by Attack Type	14
5.5.4	3.4 Evidence Preservation	15
5.6	Stage 4: Post-Incident Activity	16
5.6.1	4.1 After-Action Review Process	16
5.6.2	4.2 Continuous Improvement Metrics	16
5.6.3	4.3 Post-Incident Checklist	16



5.6.4	4.4 Lessons Learned Template	17
6	Appendices	18
6.1	Appendix A: STRIDE Quick Reference	18
6.2	Appendix B: Zero-Trust Quick Reference	18
6.3	Appendix C: Incident Response Quick Reference	18
6.4	Appendix D: Communication Templates	18

1 Executive Summary

1.1 Overview

This report presents a comprehensive security architecture blueprint for an enterprise cloud platform. The assessment covers three key areas:

1. **STRIDE Threat Modeling** - Systematic identification of threats using the STRIDE framework
2. **Zero-Trust Network Access Policy** - Implementation of Zero-Trust architecture with MFA controls
3. **Incident Response Lifecycle** - 4-stage incident response plan for high-risk compromises

1.2 Key Deliverables

Deliverable	Pages
STRIDE Threat Model	1-2
Zero-Trust Access Policy with MFA	1-2
4-Stage Incident Response Plan	2-3

1.3 Threat Landscape Summary

Threat Category	Count	Top Example
Spoofing	5	Session hijacking, DNS spoofing
Tampering	6	SQL injection, Man-in-the-Middle
Repudiation	4	Log tampering, Transaction denial
Information Disclosure	6	Data breach, Credential exposure
Denial of Service	5	DDoS, Resource exhaustion
Elevation of Privilege	5	Privilege escalation, Admin takeover

1.4 Recommendations

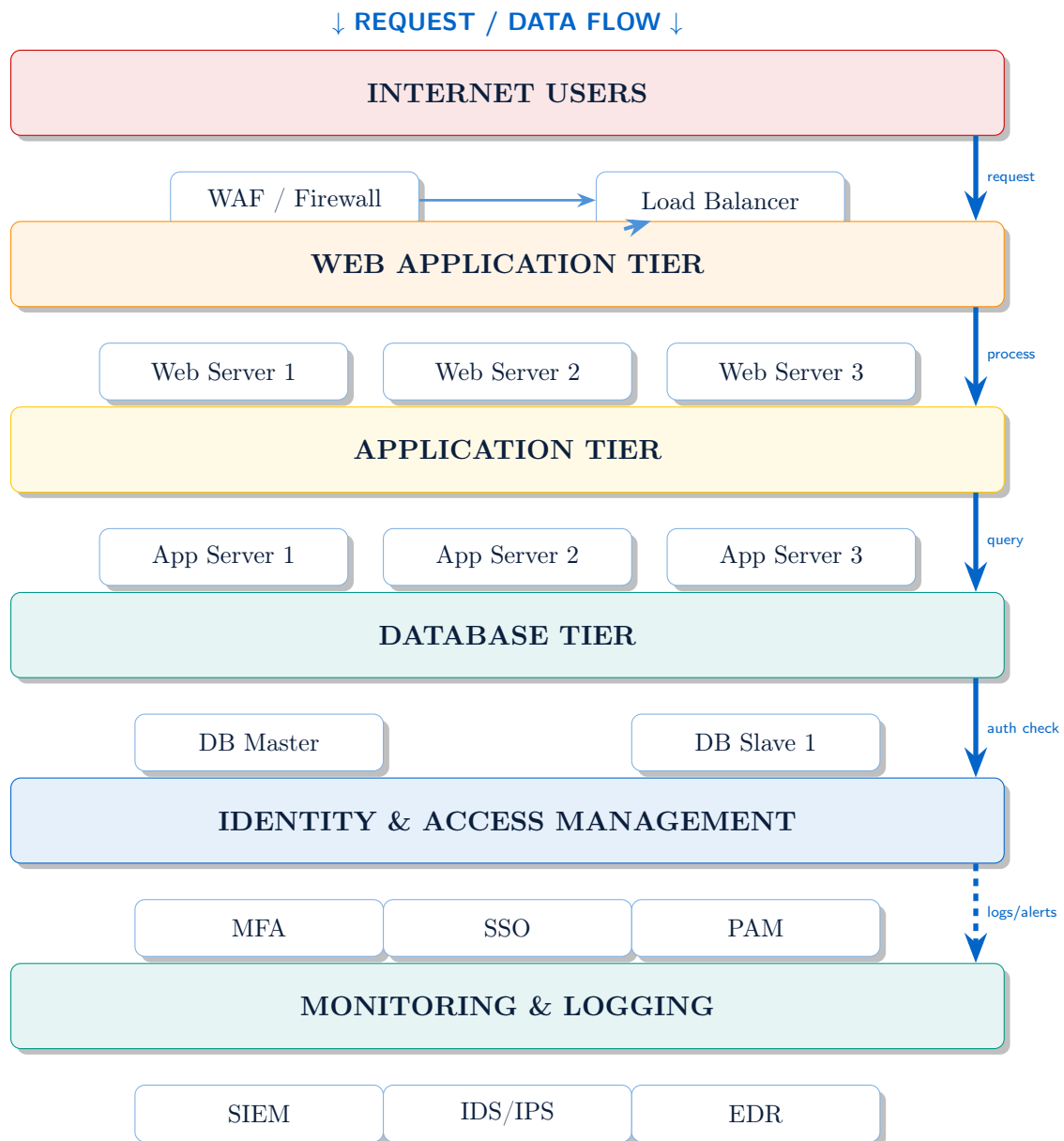
- Implement Zero-Trust architecture with mandatory MFA
- Deploy continuous monitoring and threat detection
- Establish formal incident response capability
- Conduct regular tabletop exercises

2 Enterprise System Architecture

2.1 Architecture Overview

The enterprise cloud platform consists of a multi-tier architecture designed for scalability, reliability, and security.

2.2 Architecture Diagram



2.3 Component Descriptions

Tier	Components
Internet Gateway	WAF, Firewall, Load Balancer, DDoS Protection
Web Tier	Web Servers (Nginx/Apache), CDN, SSL Termination
Application Tier	Application Servers, Microservices, API Gateway
Database Tier	Primary/Replica Databases, Backup Storage, Data Encryption
IAM	MFA, SSO, PAM, Directory Services
Monitoring	SIEM, IDS/IPS, EDR, UEBA, SOAR

3 STRIDE Threat Modeling Framework

3.1 What is STRIDE?

STRIDE is a threat modeling framework developed by Microsoft that helps identify six categories of threats:

Letter	Threat	Definition
S	Spoofing	Impersonating a user or system
T	Tampering	Modifying data in transit or at rest
R	Repudiation	Denying an action occurred
I	Information Disclosure	Exposing sensitive information
D	Denial of Service	Disrupting service availability
E	Elevation of Privilege	Gaining unauthorized access

3.2 STRIDE Threat Matrix

Component	Threat	Impact	Mitigation
SPOOFING (S)			
Internet Gateway	DNS Spoofing	Users redirected to fake site	DNSSEC, HSTS
Web Application	Session Hijacking	Attacker impersonates user	HttpOnly cookies, session rotation
Application Server	API Spoofing	Unauthorized API calls	API keys, OAuth 2.0, JWT
Database	User Impersonation	Unauthorized data access	Strong passwords, least privilege
IAM/MFA	Authentication Bypass	Account takeover	Multi-Factor Authentication
TAMPERING (T)			
Internet Gateway	Traffic Manipulation	Data interception	TLS 1.3 encryption
Web Application	SQL Injection	Database compromise	Parameterized queries, WAF
Application Server	File Inclusion	Remote code execution	Input validation, sandboxing
Database	Data Manipulation	Data corruption	Integrity checks, backups
<i>Continue on next page...</i>			

Component	Threat	Impact	Mitigation
Monitoring	Log Tampering	Cover tracks	Immutable logging
REPUDIATION (R)			
All Tiers	No Audit Trails	Cannot prove actions	Comprehensive logging
Transactions	Transaction Denial	Legal disputes	Digital signatures
User Actions	User Denies Actions	Accountability issues	Audit logs, session tracking
Admin Actions	Admin Denies Actions	Insider threat	Privileged access monitoring
INFORMATION DISCLOSURE (I)			
Web Application	Source Code Exposure	Attackers find vulnerabilities	Code obfuscation, error handling
Application Server	Memory Dumps	Sensitive data exposed	Memory encryption
Database	SQL Injection Breach	Customer data stolen	Encryption at rest, data masking
Monitoring	Log Exposure	System info revealed	Log encryption, access controls
DENIAL OF SERVICE (D)			
Internet Gateway	DDoS Attack	Service unavailable	Cloud WAF, rate limiting
Web Application	Resource Exhaustion	Performance issues	Autoscaling, load balancing
Application Server	Memory Overflow	System crash	Resource limits, monitoring
Database	Query Flooding	Database outage	Query limits, connection pooling
ELEVATION OF PRIVILEGE (E)			
Web Application	Admin Takeover	Full system compromise	MFA, least privilege
Application Server	Service Account Abuse	Unauthorized actions	Service account restrictions
Database	Root Access	Data breach	Database hardening, separation
IAM/MFA	Account Takeover	Identity compromise	Zero-Trust architecture

3.3 STRIDE Threat Summary

Threat Category	Count	Top Risk
Spoofing	5	Session Hijacking
Tampering	6	SQL Injection
Repudiation	4	Log Tampering
Information Disclosure	6	Data Breach
Denial of Service	5	DDoS Attack
Elevation of Privilege	5	Privilege Escalation

4 Zero-Trust Network Access Policy

4.1 Core Zero-Trust Principles

"NEVER TRUST, ALWAYS VERIFY"

4.2 The Five Pillars of Zero-Trust

1. Identity - Multi-Factor Authentication (MFA)

Policy Element	Implementation
MFA Requirement	Mandatory MFA for ALL users, ALL applications
Password Policy	Minimum 12 characters, complexity, 90-day rotation
Single Sign-On (SSO)	SAML 2.0 / OIDC integration
Conditional Access	Risk-based authentication (location, device, behavior)
Just-In-Time Access	Temporary privileged access (PIM/PAM)

2. Devices - Endpoint Security

Policy Element	Implementation
Device Health Checks	Compliance verification before access
Endpoint Detection	EDR solution on all devices
Mobile Device Management	MDM for all mobile devices
Trusted Devices Only	Only approved devices can connect

3. Network - Micro-Segmentation

Segment	Access Rules
Internet	Public HTTPS (443) only
DMZ	Web <-> Load Balancer <-> Internet, NO Database access
Application Tier	Web <-> App Tier, NO Database write access
Database Tier	App Tier only (read), NO direct internet access
Management	Admin VPN only, NO other access

4. Data - Encryption and Classification

Policy Element	Implementation
Encryption at Rest	AES-256 for all stored data
Encryption in Transit	TLS 1.3 for all communications
Data Classification	Labeling and access controls based on sensitivity
Data Loss Prevention	DLP controls for sensitive data

5. Continuous Monitoring

Monitor Type	Detection	Action
UEBA	Anomalous user behavior	Automated alert, Step-up authentication
SIEM	Suspicious patterns	Incident response, Alert
IDS/IPS	Network attacks	Block traffic, Alert
EDR	Malware, Process anomalies	Isolate endpoint, Alert

4.3 MFA Implementation Roadmap

Phase	Actions
Phase 1: Rollout (Months 1-3)	Enable MFA for admins, Deploy authenticator app, Test pilot group, User training
Phase 2: Expansion (Months 3-6)	MFA for privileged users, Hardware tokens (YubiKey), Conditional access, FIDO2/WebAuthn
Phase 3: Enterprise (Months 6-12)	MFA for ALL users, Biometrics, Risk-based authentication, Phishing-resistant MFA

4.4 Least Privilege Access Control

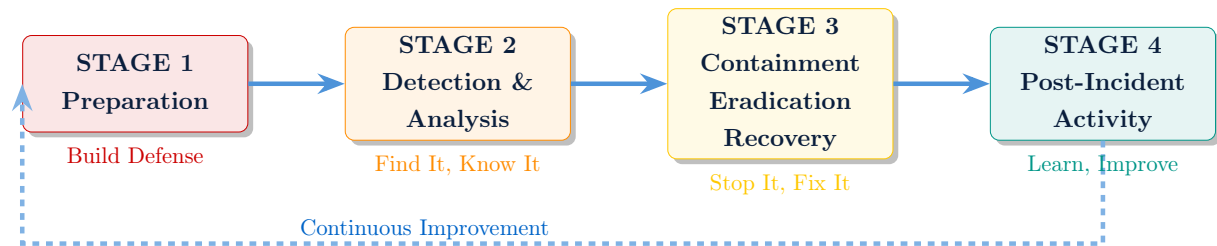
User Type	Access Rights	Conditions
Regular User	Read own data, Update own profile	MFA required, Trusted device
Power User	Read department data, Limited write	MFA + Biometric, Trusted device
Admin User	Full access to assigned systems	MFA + PIM, Privileged workstation
Service Account	API access only	Restricted IPs, Certificate-based auth
External User	Limited guest access	MFA, Time-limited

5 4-Stage Incident Response Lifecycle Plan

5.1 Overview

The incident response lifecycle consists of four stages designed to handle high-risk network compromises such as ransomware and database breaches.

5.2 Incident Response Lifecycle Diagram



5.3 Stage 1: Preparation

5.3.1 1.1 Pre-Incident Preparation Checklist

Area	Action Items	Owner
Policy	Develop IR Policy, Define roles, Create playbooks	Security Team
Tools	Deploy SIEM, EDR, SOAR, Backup solution	IT/Infrastructure
People	Train IR Team, Conduct tabletop exercises	Security Team
Process	Define escalation path, Communication plan	Management
Documentation	Create contact lists, Build runbooks	Security Team

5.3.2 1.2 Incident Response Team Structure

Role	Responsibility	Person
Incident Commander	Overall incident management	CISO/IR Lead
Lead Analyst	Technical investigation, Root cause	Security Analyst
Forensic Specialist	Evidence collection, Preservation	Forensic Expert
Communications Lead	Internal/external communications	PR/Marketing
Legal Counsel	Legal and regulatory compliance	Legal Team
IT/SysAdmin	System restoration, Log collection	IT Operations

5.3.3 1.3 Incident Classification

Severity	Description	Response Time
P1 - CRITICAL	Data breach, Active ransomware, System compromise	IMMEDIATE
P2 - HIGH	Unauthorized access, Malware infection	1-2 hours
P3 - MEDIUM	Phishing campaign, Vulnerability exploit	24 hours
P4 - LOW	Unusual traffic, Suspicious events	3-5 days

5.4 Stage 2: Detection & Analysis

5.4.1 2.1 Detection Methods

Method	Description	Tools
SIEM Alerts	Correlated log analysis	Splunk, Azure Sentinel, QRadar
EDR Alerts	Endpoint behavior monitoring	CrowdStrike, SentinelOne, Defender
Network IDS/IPS	Network traffic analysis	Snort, Suricata, Zeek
UEBA	User behavior anomalies	Exabeam, Securonix
Threat Intelligence	IOCs, Threat feeds	MISP, VirusTotal, Threat-Connect
User Reports	Employee phishing reports	Security awareness training

5.4.2 2.2 Indicators of Compromise (IOCs)

IOC Type	Examples	Detection Method
Network	Suspicious outbound IPs, Unusual ports	IDS, Firewall logs
File-based	New executables, Ransomware extensions	EDR, Anti-virus
User-based	Unusual logins, Failed MFA attempts	SIEM, IAM logs
System-based	Privilege escalation, Registry changes	EDR, System logs
Email-based	Phishing emails, Suspicious attachments	Email gateway

5.4.3 2.3 Analysis Workflow

1. **Triage:** Confirm incident, Classify severity, Assign owner
2. **Investigate:** Collect logs, Identify infected systems, Determine attack vector
3. **Document:** Timeline of events, Evidence preservation, Chain of custody

5.5 Stage 3: Containment, Eradication & Recovery

5.5.1 3.1 Ransomware Response Playbook

Phase	Actions
Containment (0-15 min)	Isolate infected systems, Block C2 IPs, Disable compromised accounts
Eradication (15 min - 2 hrs)	Remove executables, Delete processes, Remove persistence, Restore from backups
Recovery (2-6 hrs)	Restore from backups, Reinstall OS if needed, Reset passwords, Enable monitoring

5.5.2 3.2 Database Breach Response Playbook

Phase	Actions
Containment (0-30 min)	Identify compromised DB, Isolate from network, Revoke unauthorized access
Investigation (30 min - 4 hrs)	Determine data accessed, Identify attack vector, Find impacted tables
Eradication (2-4 hrs)	Patch vulnerability, Reset credentials, Apply security patches
Recovery (4-24 hrs)	Notify customers/regulators, Restore integrity, Document incident

5.5.3 3.3 Containment Strategies by Attack Type

Attack Type	Containment Strategy	Duration
Ransomware	Network isolation, System shutdown	15 minutes
Data Breach	Database isolation, Access revocation	30 minutes
DDoS Attack	Traffic rerouting, Rate limiting	10 minutes
Insider Threat	Account disablement, System lockdown	Immediate
Malware	Process termination, Network disconnect	15 minutes

5.5.4 3.4 Evidence Preservation

Evidence Type	Examples
System Evidence	Memory dumps, Running processes, Network connections, Registry entries, Log files
Network Evidence	Full packet captures, Firewall logs, IDS/IPS alerts, Proxy logs, DNS queries
User Evidence	Authentication logs, Access logs, Email records, File access history

5.6 Stage 4: Post-Incident Activity

5.6.1 4.1 After-Action Review Process

Step	Actions
Step 1: Convene Review (Within 72 hrs)	Attendees: IR Team, Management; Review timeline; Identify successes/failures
Step 2: Document Lessons (Within 1 week)	Root cause analysis; Effectiveness of detection; Timeliness of containment
Step 3: Implement Improvements (Within 2 weeks)	Update controls; Improve detection; Enhance monitoring; Update playbooks
Step 4: Report and Compliance (Within 30 days)	Final incident report; Regulatory notifications; Board communication

5.6.2 4.2 Continuous Improvement Metrics

Metric	Target	Measurement
Mean Time to Detect (MTTD)	< 1 hour	Time from incident start to detection
Mean Time to Respond (MTTR)	< 4 hours	Time from detection to containment
Mean Time to Recover (MTRec)	< 24 hours	Time from containment to full recovery
Incident Frequency	Decreasing	Number of incidents per quarter
False Positive Rate	< 5%	False alerts / Total alerts

5.6.3 4.3 Post-Incident Checklist

- Did we detect the incident quickly?
- Was the incident classified correctly?
- Was containment effective and timely?
- Was eradication complete and thorough?
- Was recovery successful and verified?
- Was communication effective?
- Are there any remaining risks?
- Are controls updated to prevent recurrence?
- Is the team debriefed and ready?

5.6.4 4.4 Lessons Learned Template

Incident Review Summary

Incident ID: _____

Date/Time: _____

Incident Type: _____

Severity: P1 / P2 / P3 / P4

What Went Well:

1. _____

2. _____

What Went Wrong:

1. _____

2. _____

Lessons Learned:

1. _____

2. _____

Improvements to Implement:

1. _____

2. _____

6 Appendices

6.1 Appendix A: STRIDE Quick Reference

Letter	Threat	Example
S	Spoofing	Password theft, Session hijacking
T	Tampering	SQL injection, Man-in-the-Middle
R	Repudiation	Log tampering, Transaction denial
I	Information Disclosure	Data breach, Credential exposure
D	Denial of Service	DDoS, Resource exhaustion
E	Elevation of Privilege	Privilege escalation, Admin takeover

6.2 Appendix B: Zero-Trust Quick Reference

1. NEVER TRUST, ALWAYS VERIFY
2. Assume breach
3. Verify explicitly
4. Use least privilege access
5. Micro-segment networks
6. Monitor continuously
7. Encrypt everything
8. Automate security responses

6.3 Appendix C: Incident Response Quick Reference

Stage	Key Activities
1: Preparation	Build defenses, Train team, Create runbooks
2: Detection and Analysis	Detect, Classify, Investigate, Document
3: Containment, Eradication and Recovery	Isolate, Remove, Restore, Verify
4: Post-Incident Activity	Review, Learn, Improve, Report

6.4 Appendix D: Communication Templates

Internal Escalation Email

TO: IR Team, Management

SUBJECT: [P1/P2/P3/P4] Security Incident - [Brief Description]

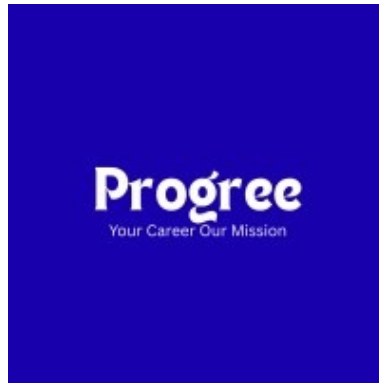
BODY: An incident has been detected and classified as [Severity Level].

Timeline: - Detection: [Time] - Initial Response: [Time] - Current Status: [Status]

Actions Taken: 1. [Action 1] 2. [Action 2]

Next Steps: 1. [Next Step 1] 2. [Next Step 2]

Contact: [Incident Commander Name] - [Contact Info]



Thank You

Prepared with diligence by

Daaniya Absar

ProGree Internship Program

Confidential – For Internal Review Only